

=====

BUMPASS FIRE & RESCUE
REPLAY-RESISTANT AUTH CONFIGURATION AUDIT
Evidence for CMMC Control 3.5.4

=====

Report Date: July 25, 2026
Prepared By: Mike Sadler, IT Administrator

=====

KERBEROS CONFIGURATION (DC01.bfr.local)

Maximum tolerance for computer clock synchronization: 5 minutes
Maximum lifetime for user ticket: 10 hours
Maximum lifetime for user ticket renewal: 7 days
Maximum lifetime for service ticket: 600 minutes
Enforce user logon restrictions: ENABLED

Kerberos uses nonce (random value) in each exchange -
replay of captured tickets rejected because:

1. Tickets contain timestamps (valid 10 hrs max)
2. Replay detection at KDC (session keys per-session)
3. Tickets include client IP and service principal binding

NTLM RESTRICTION (GPO: BFR-NTLM-Restrictions)

Restrict NTLM: Outgoing NTLM traffic: Deny all
Restrict NTLM: Incoming NTLM traffic: Deny all domain accounts
Network security: LAN Manager auth level: Send NTLMv2 only
Refuse LM and NTLM

Note: NTLM v1 completely disabled. NTLMv2 retained only for
one legacy printer that does not support Kerberos. Printer
is on isolated VLAN with no CUI data access.

CREDENTIAL GUARD STATUS (GPO: BFR-Credential-Guard)

Virtualization-based security: ENABLED
Credential Guard: ENABLED (all workstations and servers)
Pass-the-Hash risk: MITIGATED (LSASS protected by VBS)

AZURE AD - BASIC AUTH STATUS

Basic authentication to Exchange Online: DISABLED
Basic auth to SharePoint: DISABLED
Legacy auth protocols blocked: YES (Conditional Access policy)
Auth methods allowed: Modern auth only (OAuth 2.0)

=====

Certified: Mike Sadler - July 25, 2026

=====